

CloudShield AI

30 — External Integration Specification

Version 1.0 | Product-Level External Systems & Integration Specification

CloudShield AI / CloudSpartanX

Document purpose: Define how CloudShield AI integrates with external systems beyond the core cloud-provider integration boundary, including identity providers, notification channels, ticketing systems, source-control systems, CI/CD platforms, observability/security platforms, messaging/webhooks, artifact repositories, and future enterprise integrations.

Canonical principle: External integrations extend CloudShield AI capabilities but never bypass its authorization, lifecycle, policy, verification, evidence, or trusted-state controls.

1. Purpose and Scope

Document 29 defines integration with customer cloud providers. This document defines integrations with other external systems that exchange identity, events, findings, tickets, source/configuration context, notifications, artifacts, or governed workflow information with CloudShield AI.

- Define a provider-neutral external integration architecture.
- Define integration categories and ownership boundaries.
- Define inbound and outbound integration patterns.
- Define authentication, authorization, secrets, tenant isolation, and data minimization.
- Define webhooks, polling, event ingestion, and API-based synchronization.
- Define external ticketing/ITSM integration for findings and remediation workflow.
- Define source-control and CI/CD integration for infrastructure/configuration context.
- Define identity-provider integration.
- Define notification and messaging integration.
- Define security/observability integration.
- Define artifact/document/report integration.
- Define reliability, retry, deduplication, reconciliation, and audit semantics.
- Define an MVP integration baseline and future expansion path.

2. Integration Architecture

External systems connect through explicit adapters/connectors. The core domain must not import third-party SDK types or rely on vendor-specific semantics.

CloudShield AI Domain → Integration Gateway/Adapter → External Provider API/Event System

Layer	Responsibility	Examples
Core Domain	Canonical findings, candidates, users, jobs, evidence, state.	CloudShield domain services.
Integration Contract	Stable typed	ExternalIntegration interface.

Layer	Responsibility	Examples
	commands/events/data mappings.	
Adapter	Provider-specific authentication, requests, mapping, error handling.	GitHub, Jira, Slack, IdP adapters.
Integration Runtime	Scheduling, queues, retries, rate limiting, delivery.	Workers/event processors.
External System	Source of external truth or destination for synchronized information.	ITSM, SCM, IdP, messaging.

3. Integration Categories

Category	Purpose	Typical Direction
Identity	Authentication and enterprise user lifecycle.	Inbound identity →CloudShield.
ITSM/Ticketing	Findings, remediation tickets, status synchronization.	Bidirectional.
Source Control	Configuration, Terraform, pull requests, review context.	Bidirectional.
CI/CD	Build/deploy context and deployment status.	Bidirectional/event-driven.
Notifications	Alerts, approvals, operational events.	Outbound.
Webhooks	Near-real-time event delivery.	Bidirectional.
Security Platforms	Findings/events enrichment or export.	Bidirectional.
Observability	Operational telemetry and incident context.	Outbound/bidirectional.
Artifact Systems	Reports, evidence references, generated artifacts.	Outbound.
Data/Reporting	Exports and analytics pipelines.	Outbound.

4. Integration Principles

- Every integration has an explicit owner, purpose, data contract, authentication method, and failure policy.
- External systems are treated as untrusted integration boundaries.
- Integration payloads cannot directly modify trusted state.
- External events are validated, authenticated, deduplicated, and authorization-checked.
- External systems receive the minimum data necessary for the integration purpose.
- Provider-specific failures are mapped to stable CloudShield integration states.
- Long-running synchronization occurs asynchronously.
- All material inbound/outbound operations are observable and auditable.
- External integration credentials are isolated by tenant and integration.
- Disabling an integration stops new activity without silently deleting historical evidence.

5. Integration Lifecycle

State	Meaning
CONFIGURED	Configuration exists but has not been validated.

State	Meaning
VALIDATING	Connection/authentication validation in progress.
ACTIVE	Integration operational.
DEGRADED	Some operations failing or stale.
PAUSED	Temporarily disabled by policy/operator.
AUTH_FAILED	Credential/token/authorization failure.
RATE_LIMITED	Provider throttling is preventing normal operation.
DISCONNECTED	Integration intentionally removed/disabled.
REQUIRES_REAUTH	User/admin action required to restore access.

Integration state is separate from the state of the external resources synchronized through the integration.

6. Integration Registration Model

Field	Purpose
integration_id	Stable CloudShield integration ID.
tenant_id	Owning tenant.
type	Integration provider/category.
display_name	Human-readable label.
configuration	Non-secret configuration.
credential_reference	Secure secret/identity reference.
scopes	Authorized external scopes.
capabilities	Supported operations.
status	Integration lifecycle state.
last_success_at	Most recent successful operation.
last_failure_at	Most recent failed operation.
created_by	Actor that configured it.
version	Configuration/version reference.

Secrets are never returned in integration configuration APIs.

7. Authentication Patterns

Pattern	Use
OIDC/OAuth 2.0	User identity and delegated enterprise integrations.
Service account/token	System-to-system APIs where supported.
Webhook signature	Inbound/outbound event authenticity.
mTLS	High-assurance enterprise integrations where supported.
API key	Only where provider requires it; stored and scoped securely.
AWS/IAM role	AWS-specific integration covered by document 29.

- Prefer short-lived credentials and delegated authorization.
- Use least-privilege scopes.
- Store secrets in managed secret infrastructure.
- Rotate/revoke credentials without code changes.
- Record credential version/reference metadata for audit without storing secret values in domain objects.

8. Data Classification and Minimization

Data Class	Integration Rule
Public	May be exported where integration purpose allows.
Internal	Share only with authorized integrations.
Sensitive	Minimize, encrypt, and restrict destination.
Credential/Secret	Never send to external integrations unless the integration explicitly requires secure secret exchange; default is never.
Customer infrastructure evidence	Share only with tenant authorization and explicit integration policy.
AI prompt/model data	Do not forward to external systems by default.

External integrations must not become an accidental data-export mechanism for customer cloud evidence or AI context.

9. Inbound Event Architecture

Inbound events enter through an authenticated endpoint or provider-specific event receiver and are converted into canonical integration events.

1. Receive event.
2. Authenticate signature/token.
3. Validate schema and size limits.
4. Resolve integration and tenant context.
5. Deduplicate using provider event ID/idempotency key.
6. Persist raw/normalized event metadata as appropriate.
7. Authorize event effect.
8. Convert to canonical domain command/event.
9. Queue asynchronous processing.
10. Record result/evidence.
11. Return provider-compatible acknowledgement.

Inbound event receipt does not itself imply that a domain action is authorized.

10. Outbound Event Architecture

Outbound events are emitted from durable domain state changes rather than directly from UI actions.

Stage	Behavior
Domain event	Created after durable state transition.
Outbox	Persist event before delivery.
Dispatcher	Reads undelivered events.
Adapter	Transforms event to provider contract.
Delivery	Sends with timeout and authentication.
Result	Success, retryable failure, permanent failure.
Retry/DLQ	Retries bounded failures; quarantines persistent failures.
Audit	Records material delivery outcome.

An outbox pattern is recommended for reliable event delivery and avoidance of lost events.

11. Webhook Security

- Sign outbound webhook requests.
- Verify inbound webhook signatures before processing.
- Protect against replay using timestamp/event-ID validation.
- Reject oversized payloads.
- Use HTTPS.
- Rotate webhook secrets.
- Do not place long-lived credentials in webhook payloads.
- Treat webhook delivery as at-least-once unless a provider contract guarantees otherwise.

12. ITSM/Ticketing Integration

Ticketing integration connects security findings and remediation workflow to external operational processes. It does not become the authoritative owner of CloudShield candidate/trusted-state lifecycle.

CloudShield Object	External Ticket
Finding	Issue/security ticket.
RiskAssessment	Severity/priority fields.
RemediationCandidate	Change/remediation ticket.
Approval	Approval task where supported.
Promotion	Deployment/change record.
Evidence	Secure reference/attachment where policy permits.

- Store external ticket ID and URL as integration metadata.
- Synchronize selected status/priority fields only through explicit mapping.
- External ticket closure cannot automatically mark a candidate promoted.
- CloudShield lifecycle remains authoritative for verification and trusted state.
- Ticket synchronization is idempotent.

13. Source Control Integration

Source-control integrations provide configuration, Terraform, policy, pull-request, and review context.

Capability	Use
Repository discovery	Identify relevant infrastructure/configuration repositories.
File read	Retrieve authorized Terraform/configuration.
Commit metadata	Associate changes with candidate context.
Pull request	Create/review governed proposed changes where enabled.
Status checks	Publish validation/verification results.
Webhook	React to configuration changes.
Review context	Expose human review evidence.

Source control is not itself proof that a cloud change was applied. Cloud provider observations and DAIL verification remain authoritative for infrastructure state.

14. CI/CD Integration

Integration	CloudShield Use
Build events	Associate artifact/build with deployment context.
Deploy events	Detect relevant deployment activity.
Pipeline status	Inform operational/trust context.
Approval gates	Provide external workflow signal where allowed.
Security checks	Export CloudShield results into pipeline checks.
Rollback events	Trigger observation/reconciliation workflows.

- CI/CD events may invalidate candidates or trusted-state assumptions when they modify relevant infrastructure.
- Pipeline success does not equal CloudShield trusted state.
- Promotion authority remains controlled by CloudShield governance and DAIL contracts.

15. Identity Provider Integration

Enterprise authentication should support an external identity provider through OIDC/OAuth 2.0 or another approved federation mechanism.

Capability	Requirement
Login	Federated authentication.
Identity claims	Mapped to CloudShield principal.
Groups/roles	Mapped through explicit authorization configuration.
Tenant mapping	Server-controlled; never inferred solely from client input.
Token validation	Issuer, audience, expiry, signature.
Deprovisioning	Disabled identity cannot continue accessing protected resources.
MFA	Prefer provider-enforced MFA for privileged users.

External identity attributes are authentication inputs; CloudShield authorization remains server-owned.

16. Notification Integrations

Channel	Use
Email	Approval requests, security summaries, operational alerts.
Chat/messaging	Findings, incidents, job completion, approval notifications.
Webhook	Machine-to-machine event notification.
Pager/incident system	High-severity operational/security events.
In-app	Primary product notification surface.

- Notifications contain minimal sensitive information.
- High-risk actions should link to the authenticated CloudShield workflow rather than embedding executable change commands.
- Notification failure must not change domain lifecycle state.
- Notification delivery is asynchronous.

17. Security Platform Integration

CloudShield AI may exchange findings or security events with external security platforms.

Direction	Examples of Data
Inbound	External finding, alert, asset context, incident reference.
Outbound	CloudShield finding, severity, risk, evidence reference, status.
Bidirectional	Acknowledgement/status synchronization where explicitly mapped.

Imported external findings must be marked with source/provenance and must not be confused with CloudShield-native findings.

18. Observability Integration

- Export operational metrics/logs/traces through approved telemetry mechanisms.
- Never export secrets or unrestricted customer evidence.
- Use correlation IDs to connect external incidents to CloudShield jobs.
- Security-sensitive events receive appropriate retention and access controls.
- External observability systems are destinations for telemetry, not authoritative sources for trusted state.

19. Artifact and Document Integration

Artifact	Integration Use
Report	Export to approved document/storage system.
Evidence reference	Share controlled link/reference.
Terraform plan	Associate with candidate/evidence.
Verification result	Export to approved workflow/reporting system.
Audit report	Generate and distribute under policy.

Large artifacts should be referenced rather than embedded repeatedly in external API payloads.

20. Generic External Integration API

Method	Endpoint	Purpose
GET	/api/v1/integrations	List authorized integrations.
POST	/api/v1/integrations	Create integration.
GET	/api/v1/integrations/{id}	Retrieve integration metadata.
PATCH	/api/v1/integrations/{id}	Update configuration.
POST	/api/v1/integrations/{id}/test	Validate connection.
POST	/api/v1/integrations/{id}/pause	Pause integration.
POST	/api/v1/integrations/{id}/resume	Resume integration.
DELETE	/api/v1/integrations/{id}	Disconnect integration.
GET	/api/v1/integrations/{id}/events	Retrieve integration event history.

Secret values are never returned.

21. Integration Event API

Method	Endpoint	Purpose
GET	/api/v1/integration-events	List authorized events.
GET	/api/v1/integration-events/{id}	Retrieve event metadata.
POST	/api/v1/integration-events/{id}/retry	Retry a failed outbound event where safe.
POST	/api/v1/integration-events/{id}/reconcile	Reconcile ambiguous delivery/state.

Manual retry must remain subject to the same authorization and idempotency rules as automatic retry.

22. Integration Capability Model

Capability	Meaning
READ	Read external data.
WRITE	Create/update external records.
EVENT_RECEIVE	Receive provider events.
EVENT_SEND	Send CloudShield events.
TICKET_CREATE	Create tickets.
TICKET_UPDATE	Update mapped ticket fields.
SCM_READ	Read source-control content/metadata.
SCM_WRITE	Create branches/PRs/comments where enabled.
CI_STATUS	Read/publish pipeline status.
NOTIFY	Send notifications.
ARTIFACT_EXPORT	Export approved artifacts.

Capabilities are explicit per integration instance. An integration cannot exercise an operation that is not granted in its capability set.

23. Data Mapping

Each integration has a versioned mapping between CloudShield canonical objects and provider-specific objects.

Mapping Concern	Requirement
Identity	Store stable external ID + CloudShield ID.
Status	Explicit state mapping table.
Severity	Versioned mapping.
Priority	Provider-specific mapping.
Timestamp	Normalize to UTC.
URL	Validated external URL.
Evidence	Reference rather than unrestricted payload.
Unknown field	Preserve only when explicitly allowed.

Mapping changes are versioned so historical events can be interpreted correctly.

24. Synchronization Modes

Mode	Use
Push	CloudShield sends event immediately.

Mode	Use
Pull	CloudShield periodically fetches provider state.
Webhook	Provider pushes events to CloudShield.
Scheduled Sync	Periodic reconciliation.
On-demand	User/operator requests sync.
Hybrid	Webhook plus periodic reconciliation.

Critical integrations should use webhook/event delivery plus periodic reconciliation where provider capabilities permit.

25. Idempotency and Deduplication

- Every inbound event with a stable provider event ID is deduplicated.
- Outbound side-effecting operations use idempotency keys where provider support exists.
- CloudShield maintains an integration delivery record.
- Duplicate provider events must not create duplicate tickets, approvals, or domain commands.
- Repeated status synchronization must converge to the same canonical state.
- Conflicting events are retained for reconciliation rather than silently overwritten.

26. Retry and Failure Handling

Failure	Behavior
4xx validation/auth error	Usually permanent; mark failed and require correction.
429 rate limit	Retry with provider guidance.
5xx provider failure	Bounded retry/backoff.
Network timeout	Retry if operation is safely idempotent; otherwise reconcile.
Schema mismatch	Quarantine event and alert integration owner.
Credential expiry	Mark REQUIRES_REAUTH.
Destination unavailable	Queue and retry.
Ambiguous side effect	RECONCILIATION_REQUIRED.

27. Rate Limits and Backpressure

- Track provider limits per tenant/integration/provider.
- Use adaptive concurrency.
- Queue outbound operations instead of blocking domain transactions.
- Apply backpressure when destinations are unavailable.
- Protect shared CloudShield resources from a single integration consuming excessive worker capacity.
- Do not drop security-critical events silently.

28. Integration Authorization

Operation	Minimum Control
Create integration	Tenant integration-admin permission.
Read integration	Tenant-scoped integration read permission.
Test connection	Integration-management permission.
Change credentials	Integration-admin permission.

Operation	Minimum Control
Send external ticket	Integration capability + object authorization.
Export evidence	Evidence permission + integration policy.
Receive event	Authenticated provider + integration mapping.
Retry/reconcile	Integration operator permission.
Disable integration	Integration-admin permission.

An external integration must not broaden the caller's CloudShield permissions.

29. Tenant Isolation

- Each integration instance belongs to exactly one tenant.
- External IDs are namespaced by integration and tenant.
- An event received for one integration cannot access another tenant's resources.
- Shared provider installations must still resolve a tenant from trusted configuration.
- External URLs and IDs cannot be used as authorization credentials.
- Cross-tenant data export is prohibited unless an explicit, separately governed product feature is defined.

30. External Integration Security Threats

Threat	Mitigation
Forged webhook	Signature verification and replay protection.
Credential theft	Managed secrets, short-lived tokens, least privilege.
External system compromise	Minimal outbound data and capabilities.
Ticket injection	Strict field mapping and output encoding.
Malicious SCM content	Treat repository content as untrusted input.
Prompt injection via external content	AI input guardrails and provenance.
Event replay	Event IDs/timestamps/deduplication.
Data exfiltration	Tenant checks and data minimization.
SSRF	Allow-listed provider endpoints and URL validation.
Integration privilege escalation	Capability-based authorization.
Duplicate side effect	Idempotency and reconciliation.

31. Source-Control and AI Safety Boundary

Repository files, pull requests, issue descriptions, tickets, comments, and external documents can contain untrusted instructions. When such content enters AI context, it must be treated as data, not system instructions.

- Clearly separate trusted system/developer instructions from external content.
- Attach provenance to external context.
- Do not let repository/ticket text authorize cloud actions.
- AI recommendations derived from external content must pass normal validation.
- DAIL and governance remain mandatory for infrastructure-affecting changes.

32. Integration with Remediation Workflow

External integrations can participate in remediation workflow without becoming authoritative.

Finding →Candidate →External Ticket/PR →DAIL Verification →Approval →Promotion →External Status Update

- Ticket/PR creation may be automated when policy allows.
- External review can provide evidence for human governance.
- External approval is not automatically equivalent to CloudShield approval unless an explicit policy mapping exists.
- Promotion remains controlled by CloudShield.
- Post-promotion status is synchronized outward after authoritative execution.

33. Pull Request Integration

Stage	CloudShield Behavior
Candidate ready	Optionally create/update PR.
Impact analysis	Publish summary/check where allowed.
Verification	Publish verification status.
Approval	Reflect CloudShield approval state where policy allows.
Promotion	Record deployment/promotion outcome.
Drift	Open/update PR or issue when policy supports remediation workflow.

A pull request merge must not automatically be treated as proof of cloud execution unless an explicit CI/CD integration establishes an authoritative deployment event and the subsequent cloud verification succeeds.

34. External Integration Observability

Metric	Purpose
integration_requests_total	Request volume.
integration_success_total	Successful operations.
integration_failures_total	Failures by class.
integration_latency	Provider latency.
integration_retries_total	Retry pressure.
integration_queue_depth	Backlog.
integration_event_age	Staleness.
integration_auth_failures	Credential health.
integration_rate_limits	Provider throttling.
integration_reconciliation_required	Ambiguous outcomes.

Integration dashboards should expose health separately from product/domain state.

35. Evidence and Audit

- Integration configuration changes are audited.
- Credential changes/re-authentication are audited.
- Inbound security events are auditable.
- Outbound ticket/PR/notification operations are auditable.
- Evidence exports record destination and actor.
- Manual retries and reconciliation actions are audited.
- External IDs and correlation IDs allow cross-system investigation.

36. Integration Configuration Versioning

- Every material configuration change creates a new configuration version.
- Existing event records retain the mapping/configuration version used.
- Credential rotation does not require rewriting historical events.
- Changes to field mappings are reviewed and tested.
- Breaking provider changes create a new adapter/mapping version.

37. Integration API Security

Control	Requirement
Authentication	Required for protected API.
Authorization	Tenant + integration capability.
Payload validation	Schema and size validation.
Rate limiting	Per principal/tenant/integration.
Secret handling	Never return secret values.
URL validation	Allow-listed provider endpoints.
Audit	Configuration and side effects.
CORS/CSRF	Apply appropriate controls to browser-facing flows.
Error safety	No secret/provider credential leakage.

38. Testing Strategy

Test Class	Coverage
Adapter unit tests	Mapping, authentication, error conversion.
Contract tests	External provider schemas and expected behavior.
Webhook tests	Signature, replay, deduplication.
Authorization tests	Tenant/capability isolation.
Idempotency tests	Duplicate events and mutations.
Failure tests	Timeout, 429, 5xx, auth failure.
Reconciliation tests	Ambiguous external outcomes.
Security tests	SSRF, injection, credential leakage.
AI safety tests	Malicious external content entering AI context.
End-to-end tests	Ticket/SCM/CI/CD workflows in test accounts.

39. Mock and Sandbox Integrations

- Every production integration adapter should have a mock implementation.
- Provider sandbox/test environments should be used where available.
- Fixtures should include normal, stale, duplicate, malformed, unauthorized, throttled, and conflicting events.
- Local development must not require production integration credentials.
- Test tenants must use synthetic data.

40. Reliability and Recovery

- External system failure must not corrupt CloudShield domain state.
- Outbound events are durably queued.
- Inbound events can be replayed safely where supported.

- Persistent failures are visible through dashboards and alerts.
- Integration credentials can be revoked without deleting domain history.
- Recovery should reconcile external and CloudShield state before resuming sensitive synchronization.
- External outage must not automatically authorize fallback mutation paths.

41. Data Retention

Data	Retention Principle
Integration configuration history	According to audit/configuration retention.
Inbound event metadata	Retain according to security/audit needs.
Outbound delivery records	Retain enough for troubleshooting/audit.
Raw external payloads	Minimize and retain only where necessary.
External IDs/links	Retain while referenced by domain records.
Exported artifacts	Follow evidence/report retention policy.

42. External Integration MVP

- OIDC/OAuth-based enterprise authentication.
- Generic signed webhooks.
- Email/notification integration.
- One ITSM/ticketing adapter.
- One source-control adapter.
- Basic CI/CD event integration.
- Integration registry and lifecycle management.
- Capability-based authorization.
- Durable outbound event queue/outbox.
- Inbound event deduplication.
- Retry/dead-letter handling.
- Integration audit trail.
- Secure credential management.
- Mock adapters and contract tests.

Specific third-party vendors should be selected during implementation based on target users and operational requirements. The product architecture should not hard-code a vendor into the canonical domain model.

43. Future Integration Expansion

- Additional ITSM platforms.
- Additional source-control providers.
- Additional CI/CD platforms.
- SIEM/SOAR integrations.
- Enterprise messaging platforms.
- CMDB integrations.
- Cloud security posture management exports.
- Data warehouse/BI pipelines.
- Incident management platforms.
- Enterprise artifact/document systems.

- Multi-provider identity federation.

44. Integration Implementation Sequence

12. Implement generic Integration domain model.
13. Implement credential/reference and capability model.
14. Implement integration registry APIs.
15. Implement outbound event/outbox infrastructure.
16. Implement inbound webhook receiver.
17. Implement event authentication and deduplication.
18. Implement notification adapter.
19. Implement selected ITSM adapter.
20. Implement selected source-control adapter.
21. Implement CI/CD event adapter.
22. Implement integration observability and audit.
23. Implement reconciliation tooling.
24. Implement contract/sandbox tests.
25. Validate tenant isolation and security controls.
26. Document operational runbooks for each production adapter.

45. Functional Acceptance Criteria

27. An authorized tenant administrator can configure and validate an external integration.
28. Credentials are never returned by configuration APIs.
29. Inbound signed events are authenticated and deduplicated.
30. Outbound events are durable and retryable.
31. External ticket creation is idempotent.
32. External ticket status cannot bypass CloudShield lifecycle rules.
33. Source-control content can be associated with candidates without becoming authoritative cloud state.
34. CI/CD events can invalidate relevant context without directly creating trusted state.
35. Notifications do not change product lifecycle state.
36. Integration failures are visible and recoverable.
37. Integration capabilities are explicitly permissioned.
38. Cross-tenant integration access is blocked.
39. External content entering AI context is treated as untrusted data.
40. All material external side effects are auditable.

46. Security Acceptance Criteria

41. Webhook signatures are verified.
42. Replay protection is implemented.
43. Secrets are stored through managed secret infrastructure.
44. Least-privilege scopes are enforced.
45. External integrations cannot access unrelated tenants.
46. Provider URLs are validated/allow-listed where applicable.
47. Sensitive customer evidence is not exported without explicit authorization.
48. Integration credentials and tokens never appear in logs.
49. External content cannot authorize cloud mutations.
50. External system compromise does not automatically grant CloudShield promotion authority.

51. Manual retries and reconciliation require authorization and generate audit records.

47. Traceability

Source	External Integration Dependency
00 — Master System Specification	Product control loop, governance, trust model, evidence.
01 — Software Requirements Specification	Integrations, security, reliability, observability, data protection.
02 — System Architecture Specification	Integration boundaries, workers, queues, external adapters.
03 — Functional Specification	Findings, candidates, verification, promotion and reporting workflows.
04 — Product & UX Specification	Integration management, notifications, jobs, external workflow UX.
05 — Domain & Data Model	Integration, event, evidence, audit and resource relationships.
06 — State & Lifecycle	Invalidation, reconciliation, authoritative state transitions.
07 — Identity & Dependency	Stable asset/resource identity used across integrations.
08 — Security & Threat Model	Tenant isolation, credentials, external attack surface.
09 — Intelligence & AI Architecture	External content as AI context and provider abstraction.
10 — LLM Integration	AI provider boundary and data minimization.
11 — AI Safety & Guardrails	Prompt injection and external-content safety.
12–26 — DAIL subsystem	Verification, promotion, evidence, testing and governance.
27 — AWS & Terraform	CloudShield infrastructure, IAM, secrets, queues and observability.
28 — API Specification	Integration APIs, events, jobs, evidence and authorization.
29 — Cloud Integration	Customer-cloud boundary and provider adapters.

48. Engineering Decisions

Decision	Rationale
Adapter-based integrations	Prevents vendor SDK leakage into domain code.
Capability-based integration permissions	Limits each connector to explicit operations.
Outbox + durable queue	Prevents lost outbound events.
Webhook + reconciliation	Balances near-real-time response with correctness.
External systems non-authoritative	Protects CloudShield lifecycle/trusted-state semantics.
Provider-specific mappings are versioned	Supports safe evolution.
External content is untrusted	Reduces injection and authorization risks.
MVP uses selected adapters	Avoids building an unfocused integration catalog.
Integration health is separate state	Prevents provider outage from corrupting domain state.

49. Definition of Done

- Generic external integration model and APIs are implemented.
- Integration credentials are securely stored and never exposed.
- Tenant and capability isolation are enforced.
- Inbound webhook authentication and deduplication work.
- Outbound event delivery is durable, retryable, and observable.
- At least one notification, ITSM, source-control, and CI/CD integration path is operational.
- External ticket/PR operations are idempotent.
- External status cannot bypass DAIL, governance, promotion, or trusted-state controls.
- External content is marked as untrusted before entering AI context.
- Integration configuration and material side effects are audited.
- Failure, rate-limit, authentication, and reconciliation paths are tested.
- Mock/sandbox adapters support local and CI testing.
- Security and functional acceptance criteria pass.

50. Glossary

Term	Definition
External Integration	Connection between CloudShield AI and a non-core external system.
Adapter	Provider-specific implementation behind a canonical integration interface.
Integration Instance	Tenant-scoped configured external connection.
Capability	Operation explicitly permitted for an integration.
Webhook	HTTP event delivery mechanism.
Outbox	Durable store of domain events awaiting outbound delivery.
Reconciliation	Process of resolving external state that is missing, stale, conflicting, or ambiguous.
ITSM	IT service management/ticketing system.
SCM	Source-control management system.
CI/CD	Continuous integration and continuous delivery/deployment system.
Trusted State	CloudShield state earned through authoritative governed verification/promotion.